Objective 2.4 — Use the appropriate recon & enumeration tools

This objective is **tool selection**: a scenario comes in, the right tool comes out. Two questions decide almost every answer — **are you touching the target?** (passive vs active) and **what data type do you need?** (devices, DNS, email, wireless, packets, relationships). Domain 2.0 = 21%% of the exam.

1 · Tool map — by data type + passive/active

OSINT & web intel

- Wayback Machine PASSIVE
- Maltego PASSIVE
- Recon-ng BOTH
- SpiderFoot PASSIVE
- theHarvester BOTH
- Hunter.io PASSIVE
- OSINTframework.com PASSIVE

Internet-exposure scanners

- Shodan PASSIVE
- Censys.io PASSIVE

DNS & domain

- WHOIS PASSIVE
- nslookup / dig ACTIVE
- DNSdumpster PASSIVE
- Amass BOTH

Active network & capture

- Nmap + NSE ACTIVE
- Wireshark / tcpdump BOTH

Wireless

- WiGLE.net PASSIVE
- InSSIDer ACTIVE
- Aircrack-ng ACTIVE

Q1 TOUCHING TARGET?	Q2 DATA TYPE?	Q3 WHICH ONE?
no traffic -> passive; direct probes -> active	devices/DNS/email/wireless/packets/relationships	break ties via the comparisons

2 · Tool cards

All 18 official tools — what it is, passive/active, key facts, exam tell. Grouped by family.

OSINT & WEB INTEL

Wayback Machine PASSIVE

Historical website snapshots (Internet Archive).

- Recovers **old login/admin portals** (and their URL naming conventions)
- Removed docs, outdated software refs, subdomains no longer linked
- Accidentally-published secrets that were briefly live
- **Zero packets to the target** — ideal early stealth recon

EXAM TELL "historical / archived web content" or "a portal removed years ago" -> Wayback Machine.

Maltego PASSIVE

Graphical OSINT — **entities + transforms** build a relationship graph.

- Seed entity (domain) -> transforms query public sources -> IPs, subdomains, people, mail
- Visualizes **connections** between data points (link analysis)
- Editions: CE (free, limited) / Pro / Enterprise

EXAM TELL "visualize relationships / map connections between entities" -> Maltego.

Recon-ng BOTH

Modular, scriptable OSINT framework — **Metasploit-like**.

- **Workspaces + modules** (Discovery/Recon/Import/Reporting); SQLite DB-backed
- Scriptable automation; many modules need API keys
- CLI, organized, repeatable — built for large engagements

EXAM TELL "modular / scriptable / Metasploit-like OSINT framework" -> Recon-ng.

SpiderFoot PASSIVE

Automated OSINT across **100+ sources**, auto-correlated.

- Accepts domain/IP/email/username/ASN/name/phone/BTC as seed
- Queries DNS, WHOIS, Shodan/Censys, HIBP, CT logs, paste sites, GitHub
- **Most automated** — minimal manual config after the seed

EXAM TELL "100+ data sources / broad automated sweep, minimal config" -> SpiderFoot.

theHarvester BOTH

CLI harvester of emails, subdomains, hosts, IPs, ports.

- `theHarvester -d domain -b google,linkedin,shodan -l 500`
- Broad data (not just email) from many search engines + Shodan/crt.sh
- Fast quick-sweep for initial email + subdomain recon

EXAM TELL "broad OSINT incl subdomains + IPs from search engines (CLI)" -> theHarvester.

Hunter.io PASSIVE

Email intelligence — find + **verify** professional emails by domain.

- Domain search, Email Finder, Email Verifier (SMTP handshake, no send)
- Reveals the org **email format pattern** (first.last@…) + confidence scores
- Feeds spear-phishing / password-spraying target lists

EXAM TELL "email addresses + verification / confidence / format pattern" -> Hunter.io.

OSINTframework.com PASSIVE

A curated **directory** of OSINT tools (interactive tree) — not a tool itself.

- Categories: username, email, domain, IP, social, geo, dark web…
- Legend icons: (T)/(R) registration, (D) Google dork, (!) may be illegal
- A **reference map** — it does not gather intelligence itself

EXAM TELL "directory / reference of OSINT tools" -> OSINTframework.com (finds tools, gathers nothing).

INTERNET-EXPOSURE SCANNERS

Shodan PASSIVE

Search engine for **internet-connected devices** (indexes banners).

- Operators: `org:` `net:` `port:` `hostname:` `product:` `vuln:`
- Strong on **IoT / ICS / SCADA**, exposed databases, VPN, cameras
- Queries a pre-collected DB — target sees no traffic

EXAM TELL "internet-connected / IoT / ICS devices without scanning" -> Shodan.

Censys.io PASSIVE

Internet-wide scanner with **structured data + deep certificate intel**.

- SQL-like structured queries; daily IPv4 scans; API; academic origin (UMich)
- SSL/TLS **certificate** chains + **SANs -> subdomains** (dev/staging)
- Better than Shodan for certificates & precise structured queries

EXAM TELL "certificate intelligence / structured queries / SAN subdomains" -> Censys.

DNS & DOMAIN

WHOIS PASSIVE

Registration lookup for domains and IP blocks.

- Domain: registrant, contacts, dates, name servers, registrar
- IP: owning org, CIDR range, abuse contact via **RIRs** (ARIN/RIPE/APNIC/LACNIC/AFRINIC)
- Privacy hides contacts, but NS + dates + registrar remain

EXAM TELL "domain registration / IP-block ownership / which RIR" -> WHOIS.

nslookup / dig ACTIVE

DNS query tools — send **direct queries** to DNS servers.

- Records: A/AAAA, MX, NS, CNAME, PTR, TXT, SOA, **SRV**
- `dig -x` reverse; `dig … AXFR @ns` zone transfer; dig preferred (detail, scripting)
- nslookup is on Windows by default and has an interactive mode

EXAM TELL "DNS record queries / zone transfer" -> dig; Windows box -> nslookup.

DNSdumpster PASSIVE

Web-based **passive** DNS recon with a visual map.

- Subdomains, A/MX/NS/TXT, hosting relationships; free, no account
- Distinctive **visual domain map** (like a lightweight Maltego)
- Can reveal open mail relays; by HackerTarget

EXAM TELL "passive DNS map with visual output, no install" -> DNSdumpster.

Amass BOTH

OWASP **comprehensive** subdomain enum + attack-surface mapping.

- Subcommands: `enum` `intel` `db` `viz` `track`
- Passive (CT logs, passive DNS, search, WHOIS) **+** active (brute, AXFR, recursive)
- Recursive discovery + graph DB — the most thorough DNS tool

EXAM TELL "most comprehensive subdomain enum, passive AND active" -> Amass.

ACTIVE NETWORK & CAPTURE

Nmap + NSE ACTIVE

The network scanner — host discovery, ports, service/OS, Lua scripts.

- Scans: `-sS` SYN(root/stealth) · `-sT` connect(no root) · `-sU` UDP · `-sF/-sN/-sX` · `-sI` idle
- States: open / closed / filtered / **open|filtered** (UDP)
- `-sV` version · `-O` OS · `-A` aggressive · `-Pn` skip disc · `-sn` ping-only
- **NSE** categories (default/vuln/brute/discovery/safe/intrusive); `-T0..-T5`; `-oA`

EXAM TELL a flag in the stem IS the question; `-sS` needs root, `-sT` does not.

Wireshark / tcpdump BOTH

Packet **capture + analysis**.

- tcpdump: CLI `-i -n -w -r -c` + **BPF filters**; Wireshark: GUI, display filters, Follow TCP Stream
- Captures **cleartext creds** on HTTP/FTP/Telnet/SNMPv1-2c; reads/writes **PCAP**
- IoT/OT dissectors (Modbus/DNP3); remote = `tcpdump -w-` piped into Wireshark

EXAM TELL "capture traffic / cleartext creds / PCAP" -> Wireshark/tcpdump; remote capture -> tcpdump into Wireshark.

WIRELESS

WiGLE.net PASSIVE

Crowdsourced **global** wireless AP database (web).

- Indexes SSID/BSSID/encryption/GPS/first-last-seen from wardriving data
- **Remote** pre-engagement recon — no physical presence needed
- Reveals SSID reuse across sites; historical records

EXAM TELL "wireless recon remotely / before arriving on-site" -> WiGLE.

InSSIDer ACTIVE

Real-time **local** Wi-Fi analyzer / survey.

- Shows SSID/BSSID/channel/RSSI/encryption/802.11 mode/vendor OUI
- **Channel-overlap** viz (1/6/11 non-overlapping); rogue-AP + evil-twin prep
- Survey only — does not capture packets or crack

EXAM TELL "on-site real-time wireless analysis / channels" -> InSSIDer.

Aircrack-ng ACTIVE

Wireless auditing **suite** — capture -> attack -> crack.

- **airmon-ng** monitor mode -> **airodump-ng** capture -> **aireplay-ng** deauth -> **aircrack-ng** crack
- WEP via IV collection; WPA/WPA2 via captured **4-way handshake** + wordlist
- airbase-ng = fake AP / evil twin

EXAM TELL "WPA handshake / deauth / monitor mode / crack" -> Aircrack-ng (deauth = aireplay-ng).

3 · Critical comparisons

Same category, different best fit — the amber line names the split.

Shodan vs Censys — Both passive internet scanners — split by data type.

Shodan PASSIVE	Censys PASSIVE
IoT / ICS device discovery; simpler; broadest device types.	**Certificate** intelligence + SQL-like **structured** queries.

WiGLE vs InSSIDer — Both wireless intel — split by where you are.

WiGLE.net PASSIVE	InSSIDer ACTIVE
Remote, historical, web-based — no physical presence.	**On-site**, real-time RF survey of nearby APs.

theHarvester vs Hunter.io — Both surface emails — split by scope.

theHarvester BOTH	Hunter.io PASSIVE
CLI, **broad** (emails + subdomains + IPs + ports).	Web, **email-focused** with verification + confidence.

Maltego vs Recon-ng vs SpiderFoot — All OSINT frameworks — split by style.

Maltego PASSIVE	Recon-ng BOTH	SpiderFoot PASSIVE
GUI relationship visualization; manual transforms.	**CLI modular**, Metasploit-like, DB-backed, scriptable.	**Most automated**; 100+ sources; minimal config.

nslookup vs dig — Both query DNS.

nslookup ACTIVE	dig ACTIVE
On **Windows** by default; simpler; interactive mode.	**Linux**, detailed output, scripting, supports **AXFR**.

InSSIDer vs Wireshark vs Aircrack-ng — All touch wireless — split by intent.

InSSIDer ACTIVE	Wireshark BOTH	Aircrack-ng ACTIVE
Enumeration — shows what APs are there.	**Capture + analyze** traffic (passive inspection).	**Active attacks** — deauth, handshake, crack.

4 · Nmap / Aircrack / DNS reference

Nmap + NSE

Scan types

`-sS`	SYN / half-open — stealth, needs root
`-sT`	TCP connect — no root, more logged
`-sU`	UDP scan — slow, ICMP-based
`-sF / -sN / -sX`	FIN / NULL / Xmas — filter bypass
`-sI`	Idle (zombie) — highly stealthy

Port states

`open`	service accepting connections
`closed`	reachable, nothing listening
`filtered`	firewall blocking probes
`open|filtered`	can't tell (common on UDP)

Detect / discovery

`-sV`	service/version
`-O`	OS fingerprint
`-A`	aggressive: -sV+-O+-sC+traceroute
`-Pn`	skip host discovery
`-sn`	ping-only (no port scan)
`-PR / -PS / -PA`	ARP / SYN / ACK ping

Timing / output / evasion

`-T0..-T5`	paranoid->insane (T0/T1 evade IDS, T3 default)
`-oN / -oX / -oG / -oA`	normal / XML / grepable / all
`-D RND:10`	decoy scan

NSE categories

`-sC / default`	safe common scripts
`vuln`	known-vuln checks
`brute`	credential brute
`discovery`	network discovery
`intrusive`	may crash/log
`--script=name`	run a specific script

Aircrack-ng suite (capture → attack → crack)

`airmon-ng`	enable monitor mode (creates wlan0mon)
`airodump-ng`	passive capture + network discovery (BSSID/CH/ENC/ESSID)
`aireplay-ng`	packet injection + **deauth** (forces handshake)
`aircrack-ng`	crack WEP (IVs) / WPA (4-way handshake + wordlist)
`airbase-ng`	create a fake AP / evil twin

DNS record types

`A / AAAA`	hostname -> IPv4 / IPv6
`MX`	mail servers
`NS`	authoritative name servers
`CNAME`	alias -> another hostname (CDN/3rd-party)
`PTR`	reverse: IP -> hostname

`SOA`	zone admin info
`TXT`	SPF / DKIM / verification (sometimes sensitive)
`SRV`	hidden services (SIP/LDAP/VoIP)

5 · Scenario decoder — clue in the stem → tool

How the exam phrases it. Match the clue, name the tool.

CLUE IN THE QUESTION	TOOL
"without touching the target"	Passive: Shodan, Censys, WiGLE, Wayback
"historical website data"	Wayback Machine
"visualize relationships"	Maltego
"automate reconnaissance / modular"	Recon-ng
"100+ data sources / broad automated"	SpiderFoot
"internet-connected / IoT / ICS devices"	Shodan
"certificate data / structured query"	Censys.io
"domain registration / IP ownership"	WHOIS
"DNS records / zone transfer"	dig (nslookup on Windows)
"email addresses + verification"	Hunter.io
"broad emails + subdomains + IPs"	theHarvester
"DNS infrastructure, visual map"	DNSdumpster
"most comprehensive subdomain enum"	Amass
"port / service scanning"	Nmap
"script-based scanning"	Nmap NSE
"wireless networks remotely / pre-engagement"	WiGLE.net
"on-site wireless channels/signal"	InSSIDer
"OSINT tool reference/directory"	OSINTframework.com
"packet capture / PCAP / cleartext creds"	Wireshark / tcpdump
"WPA handshake"	Aircrack-ng
"deauthentication"	aireplay-ng (Aircrack-ng)
"no completed TCP handshake / stealth scan"	Nmap -sS
"scan without root privileges"	Nmap -sT

6 · Which-tool quiz (answer key included)

Scenario in, tool out — weighted toward the confusable pairs.

Q01

A tester must catalog all internet-facing IoT and ICS devices for the target without sending any traffic to them.

Which tool?

Shodan Internet-exposure

WHY Shodan indexes internet-connected devices (incl. IoT/ICS) from its own pre-collected banner database — no target traffic.

Q02

The tester wants every subdomain a target owns, discovered from SSL/TLS certificate data using precise structured queries.

Which tool?

Censys.io Internet-exposure

WHY Censys excels at certificate intelligence and SQL-like structured queries; SANs in certs expose subdomains. Shodan is the IoT/device pick, not this.

Q03

Before flying to a client site, the tester wants to know what wireless networks (SSIDs, encryption) exist there.

Which tool?

WiGLE.net Wireless

WHY WiGLE is remote/passive — a crowdsourced global AP database queried before arriving. InSSIDer would require being on-site.

Q04

On-site, the tester needs real-time channel usage, signal strength, and encryption of nearby APs.

Which tool?

InSSIDer Wireless

WHY InSSIDer is the active, local, real-time survey tool. WiGLE is remote/historical; Aircrack-ng is for attacks, not survey.

Q05

The tester needs verified email addresses and the org's email format pattern for a spear-phishing list.

Which tool?

Hunter.io OSINT

WHY Hunter.io is email-specific with verification, confidence scores, and format-pattern detection. theHarvester is broader but doesn't verify like this.

Q06

The tester wants a visual graph mapping the relationships between a domain, its people, and its IP infrastructure.

Which tool?

Maltego OSINT

WHY Maltego's entities + transforms produce a relationship graph — the visualization tool. Recon-ng/SpiderFoot are non-visual frameworks.

Q07

The tester wants a fully automated OSINT sweep across 100+ sources with minimal manual configuration.

Which tool?

SpiderFoot OSINT

WHY SpiderFoot is the most automated (100+ sources, seed-and-go). Recon-ng needs manual module loading; Maltego needs manual transforms.

Q08

The tester wants a modular, scriptable, Metasploit-like framework that stores OSINT in a database.

Which tool?

Recon-ng OSINT

WHY Workspaces + modules + SQLite DB + scriptability = Recon-ng. SpiderFoot is more automated; Maltego is GUI/visual.

Q09

The tester needs web application paths that existed on the site two years ago but have since been removed.

Which tool?

Wayback Machine OSINT

WHY Historical snapshots are exactly the Wayback Machine's purpose — recovering removed content and old URL paths.

Q10

The tester wants the single most thorough subdomain enumeration, combining passive sources with active brute forcing.

Which tool?

Amass DNS

WHY Amass is the OWASP comprehensive tool combining passive (CT/passive DNS) and active (brute/AXFR/recursive) methods.

Q11

The tester must scan a target without completing TCP handshakes to reduce detection.

Which flag?

Nmap -sS Active

WHY The SYN/half-open scan never finishes the handshake (stealth). Note it requires root; -sT (connect) is the no-root alternative.

Q12

The tester needs to force a client to reconnect so a WPA2 4-way handshake can be captured.

Which technique/tool?

Deauthentication with aireplay-ng Wireless

WHY aireplay-ng -0 sends deauth frames, forcing reconnection and a fresh handshake for airodump-ng to capture, then aircrack-ng cracks it.

Q13

The tester wants to capture traffic on a remote Linux server and analyze it locally in a GUI.

Which combination?

tcpdump piped into Wireshark Active

WHY tcpdump -w- over SSH into Wireshark (-k -i -) gives remote capture + local graphical analysis without installing Wireshark remotely.

Q14

The tester needs the target's owned IP ranges (CIDR) and the technical contact on record.

Which tool?

WHOIS DNS

WHY WHOIS returns registrant/technical contacts, name servers, and IP-block/CIDR ownership via the RIRs.

7 · Keyword → tool reference

KEYWORD / PHRASE	TOOL
without touching the target	use a passive tool
historical / archived pages	Wayback Machine
transforms / entities / relationship graph	Maltego
workspaces + modules / Metasploit-like	Recon-ng
100+ data sources / most automated	SpiderFoot
org: net: port: vuln: (operators)	Shodan
IoT / ICS / SCADA devices	Shodan
certificate intel / SAN subdomains / structured query	Censys.io
registrant / RIR / IP-block ownership	WHOIS
ARIN / RIPE / APNIC	WHOIS (regional registries)
A/MX/NS/PTR/TXT/SRV records	dig / nslookup
dig -x	reverse DNS (PTR)
AXFR / zone transfer	dig
visual DNS map / no install	DNSdumpster
recursive subdomain enum / passive+active	Amass
OWASP / amass enum	Amass
email finder / verifier / confidence / format	Hunter.io
-d domain -b sources	theHarvester
emails + subdomains + IPs (CLI, broad)	theHarvester
directory of OSINT tools / not a tool	OSINTframework.com
-sS / -sT / -sU / -sV / -O / -A	Nmap flags
open|filtered	Nmap UDP port state
NSE / --script= / Lua	Nmap Scripting Engine
-Pn skip discovery / -sn ping-only	Nmap host discovery
PCAP / BPF filter / Follow TCP Stream	Wireshark / tcpdump
cleartext credentials capture	Wireshark / tcpdump
crowdsourced wireless DB / remote	WiGLE.net
channel overlap / real-time survey	InSSIDer
monitor mode / wlan0mon	airmon-ng (Aircrack-ng)
airodump-ng / aireplay-ng / deauth	Aircrack-ng suite
4-way handshake / WPA crack	aircrack-ng
WEP via IV collection	aircrack-ng